セキュリティ付録 脅威と多層防御の対応

印刷用PDF版 v1.0.0 | 2026-11-11 JST

著者 竹内政夫（Masao Gate Labs）。統合シリーズ v1.1（2026年10月24日）の付録Sに基づく公開編集版。原稿の研究・執筆支援は Microsoft Copilot、公開編集と英訳の支援は ChatGPT。

独立研究として公開します。AIサービス提供元による共同研究、査読、承認、支持を示すものではありません。

脅威を制御点と結びつける

OWASP、MITRE ATLAS、NISTの脅威の語彙を参照し、各対策が予防、検知、封じ込め、復旧のどこを担うかを整理します。以下の対応は設計上の位置づけです。OWASP · MITRE ATLAS · NIST AI 100-2e2025

例	主に扱う範囲	残る課題
プロンプトインジェクション	外部操作を独立に認可し、権限外の影響を制限する	入力の検出、隔離、入力や文脈の信頼性確認
過剰な権限	能力と権限を分け、対象・操作・再委任を制限する	権限の発行条件、変更と失効の検証
機密情報の露出	対象と操作を制限し、記録する	データ分類、出力制御、保存と閲覧の管理
供給網の変更・汚染	変更を検知し、再評価や事案対応へつなぐ	来歴確認と汚染検出の個別対策
消費の上限超過	操作範囲と実行資源の制御	並行実行時の累積量、費用、通知の扱い

読み取りだけを委ねたエージェントに、削除機能を持つツールが見えている場合を考えます。削除の提案が生成されても、対象に対する削除権限がなければ実行制御点で拒否する設計です。実行環境の分離や処理中データの保護も、それぞれ異なる境界を担当します。停止や再認可まで含め、いずれかの制御に不具合が起きた場合の残る影響を評価します。

追加の接続点

- SEC-X1 入力と取得した文脈の信頼性に関する情報を判断点へ渡す
- SEC-X2 モデル出力を外部操作へ変換する前に検証する
- SEC-X3 資源・実行時間・費用の上限を実行制御につなぐ
- SEC-X4 モデル・ツール・依存関係・データの由来や変更を適合評価へ渡す
- SEC-X5 機密データの分類と取扱条件を権限と実行制御に反映する

接続点は研究上の提案です。制御の網羅性や実効性は、前提条件と観測範囲を明示した試験で評価します。

第003論文 · 研究シリーズ · 事案分析

版を固定したWeb記録